

Securing the Cloud

Hardening a Public-Facing AWS EC2 Web Server: IAM, CIS

Benchmarks and Vulnerability Management

Prepared by: Vignesh Gopal Kalaivani

Project: AWS EC2 Security Hardening - Home Lab Portfolio Project

Instance: project2-web-server (i-0b7e1e5d71fe8b991), Debian 13

Project Overview

This project simulates hardening a real, public-facing AWS EC2 web server end-to-end: standing up the environment, restricting access, establishing least-privilege identity, enabling logging and auditability, applying CIS Benchmark compliance controls, and performing vulnerability scanning and remediation. Every control below was applied and independently verified - not assumed to work.

Toolkit

- AWS EC2, IAM, CloudWatch, CloudTrail, GuardDuty, AWS Inspector
- Debian 13, Apache HTTP Server
- CIS Benchmark (Debian), UFW, AIDE, unattended-upgrades
- Lynis, rkhunter, fail2ban
- Bash scripting (cis_harden.sh)
- OWASP Top 10 for Cloud Security (reference framework)

Day 1 - Standing Up the Target

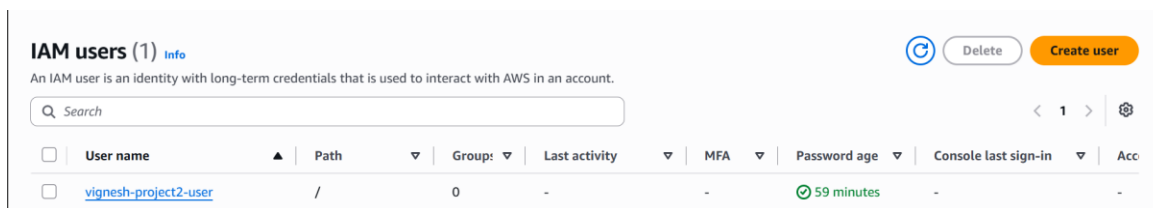
Goal: create an isolated AWS environment and launch a real, publicly reachable web server to serve as the target for all later security work.

1. Create AWS Account

A new AWS account was created to host the project in isolation from any pre-existing infrastructure.

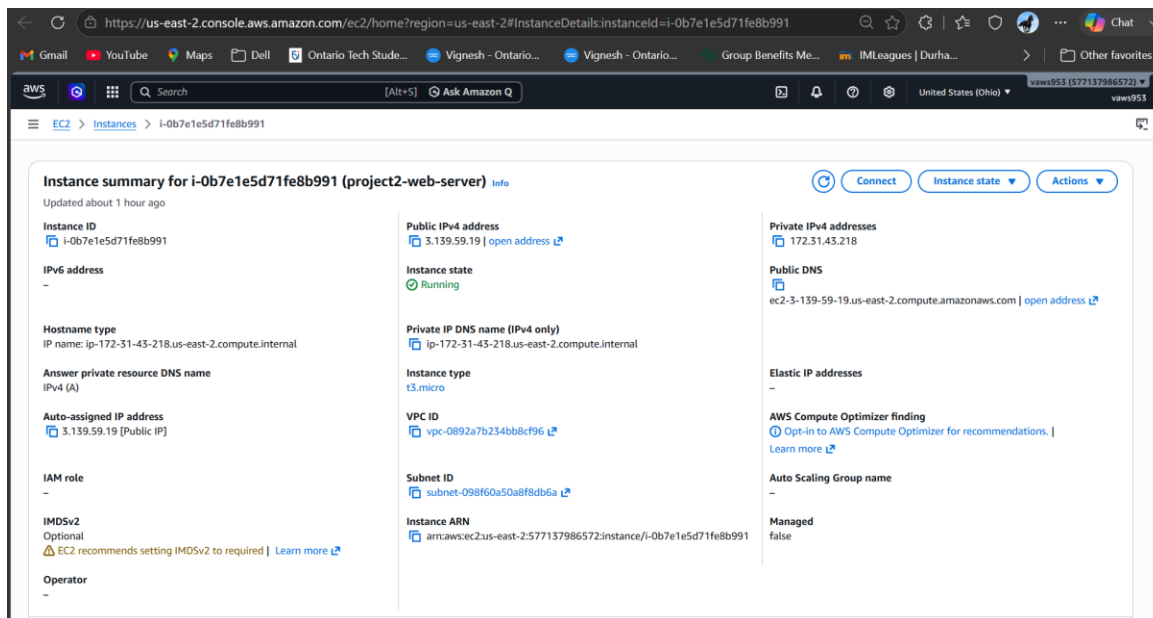
2. Create IAM User

A dedicated IAM user was created immediately, so no project work would be performed under the AWS root account - a foundational cloud security practice.



3. Launch EC2 Instance

An EC2 instance running Debian 13 was launched to serve as the target server.



4. Configure Web Server

Apache was installed and configured as the basic web server on the instance.

```
admin@ip-172-31-43-218:~$ sudo apt install apache2 -y
apache2 is already the newest version (2.4.68-1~deb13u1).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0
```

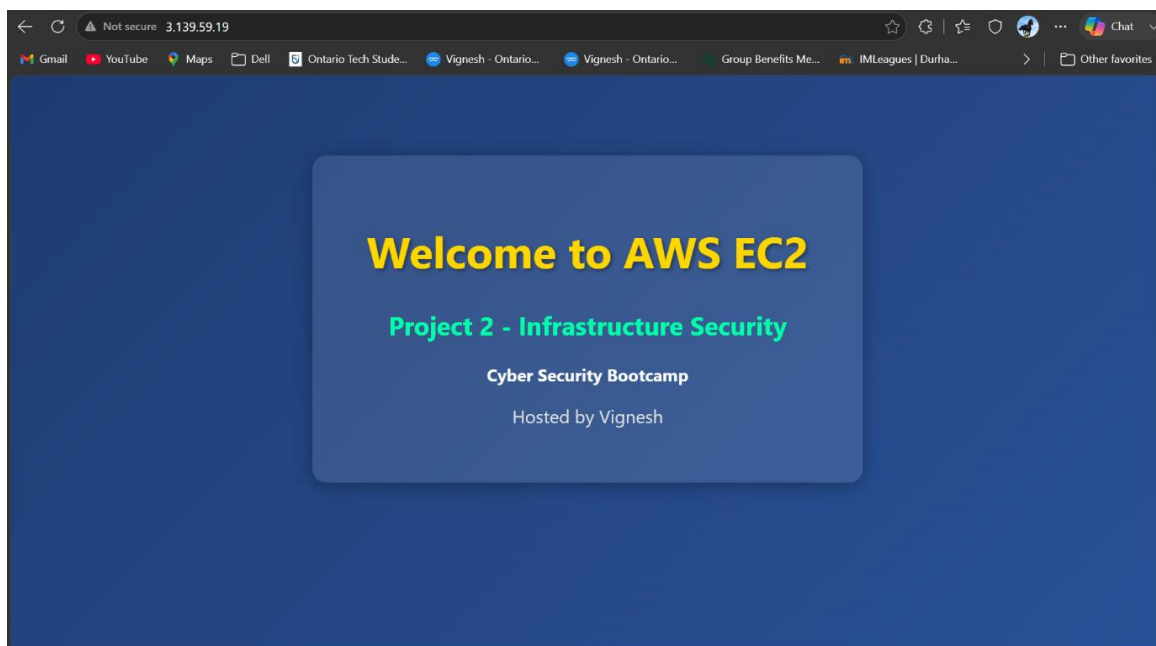
```
admin@ip-172-31-43-218:~$ sudo systemctl start apache2
admin@ip-172-31-43-218:~$ sudo systemctl enable apache2
Synchronizing state of apache2.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable apache2
```

```
admin@ip-172-31-43-218:~$ systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-07-23 17:48:42 UTC; 2min 13s ago
  Invocation: 0014fffd58682489abdb33c0d247b1af1
     Docs: https://httpd.apache.org/docs/2.4/
    Main PID: 9811 (apache2)
       Tasks: 55 (limit: 1097)
      Memory: 5M (peak: 5.4M)
         CPU: 48ms
    CGroup: /system.slice/apache2.service
            └─9811 /usr/sbin/apache2 -k start
               └─9813 /usr/sbin/apache2 -k start
                  └─9814 /usr/sbin/apache2 -k start

Jul 23 17:48:42 ip-172-31-43-218 systemd[1]: Starting apache2.service - The Apache HTTP Server >
Jul 23 17:48:42 ip-172-31-43-218 apachectl[9810]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 172.31.43.218. Set the 'ServerName' directive globally to suppress this message
Jul 23 17:48:42 ip-172-31-43-218 systemd[1]: Started apache2.service - The Apache HTTP Server >
```

5. Webpage Live

Result: a live, publicly reachable webpage at <http://3.139.59.19>

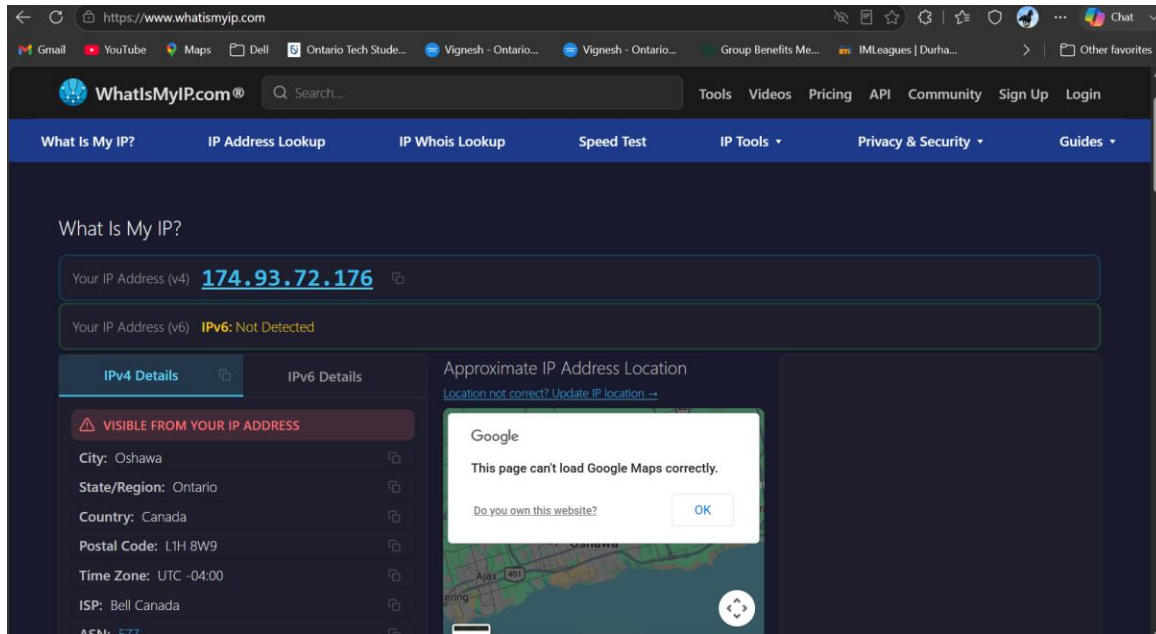


Day 2 - Locking Down Access: SSH, IAM, Logging & CIS Hardening

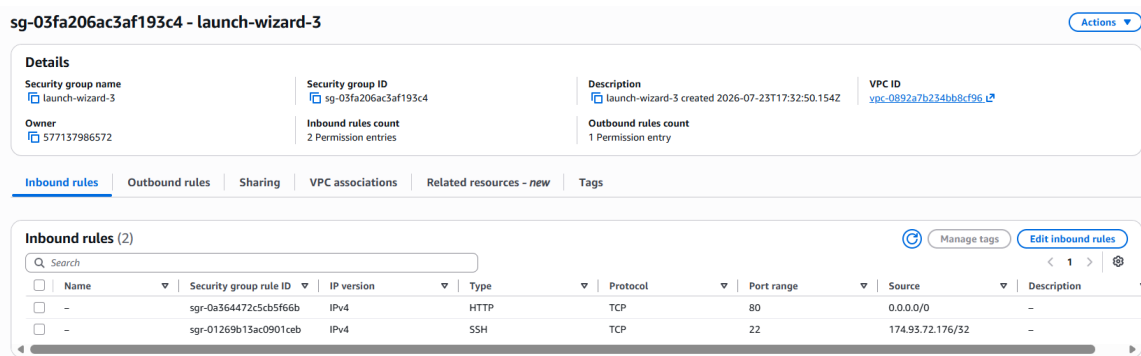
Prepared by: Vignesh | Date: July 23, 2026 | Instance: project2-web-server (i-0b7e1e5d71fe8b991), Debian 13

Task 1: Restrict SSH to Your IP Only

1. Finding my IP



2. Edit the Security Group



3. Testing it

```
C:\Users\vigne\Downloads>ssh -i "mykey.pem" admin@3.139.59.19
Linux ip-172-31-43-218 6.12.74+deb13+1-cloud-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1
2.74-2 (2026-03-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Jul 23 17:44:25 2026 from 174.93.72.176
```

Task 2: Least-Privilege IAM User for the Web Server

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "ec2:DescribeInstances",
        "ec2:StartInstances",
        "ec2:StopInstances",
        "ec2:RebootInstances"
      ],
      "Resource": "arn:aws:ec2:us-east-2:577137986572:instance/i-0b7e1e5d71fe8b991"
    }
  ]
}
```

[Alt+S]
Global ▾

IAM > Policies > WebServer-LeastPrivilege-Policy

Policy WebServer-LeastPrivilege-Policy created.

[< Services](#) Actions in EC2 (3 of 793)
Sho

Write (3 of 497)

Action	Resource	Request condition
RebootInstances	InstanceID string like i-0b7e1e5d71fe8b991, region string like us-east-2	None
StartInstances	InstanceID string like i-0b7e1e5d71fe8b991, region string like us-east-2	None
StopInstances	InstanceID string like i-0b7e1e5d71fe8b991, region string like us-east-2	None

User details

User name webserver-user	Console password type Custom password	Require password reset No
-----------------------------	--	------------------------------

Permissions summary
< 1 >

Name ↗	Type	Used as
WebServer-LeastPrivilege-Policy	Customer managed	Permissions policy

Step 1

Specify user details

Step 2

Set permissions

Step 3

Review and create

Step 4

Retrieve password

Retrieve password

You can view and download the user's password below or email users instructions for signing in to the AWS Management Console. This is the only time you can view and download this password.

Console sign-in details

Console sign-in URL
https://577137986572.signin.aws.amazon.com/console

User name
webserver-user

Console password
***** Show

CancelDownload .csv fileReturn to users list

EC2

Dashboard

AWS Global View

Events

Instances

Instance Types

Launch Templates

Spot Requests

Savings Plans

Reserved Instances

Dedicated Hosts

Capacity Reservations

Capacity Manager

Images

AMIs

AMI Catalog

Elastic Block Store

Volumes

Snapshots

Lifecycle Manager

Network & Security

Security Groups

Elastic IPs

Placement Groups

Key Pairs

Network Interfaces

IPV6 address

Hostname type

Answer private resource DNS name

Auto-assigned IP address

IAM role

IMDSv2

Operator

Instance state

Private IP DNS name (IPv4 only)

Instance type

VPC ID

Subnet ID

Instance ARN

Public DNS

Elastic IP addresses

AWS Compute Optimizer finding

Auto Scaling Group name

Managed

Details

Status and alarms

Monitoring

Security

Networking

Storage

Tags

Instance details

AMI ID

AMI name

Stop protection

Monitoring

Allowed image

Launch time

Platform details

Termination protection

AMI location

EC2

Dashboard

AWS Global View

Events

Instances

Instance Types

Launch Templates

Spot Requests

Savings Plans

Reserved Instances

Dedicated Hosts

Capacity Reservations

Capacity Manager

Images

AMIs

AMI Catalog

Elastic Block Store

Volumes

Snapshots

Lifecycle Manager

Network & Security

Security Groups

Elastic IPs

Placement Groups

Key Pairs

Network Interfaces

Failed to stop the instance i-0b9c186632946d478

Diagnose with Amazon Q

Instances (1/2)

Save filter sets

Find instance by attribute or tag (case-sensitive)

Instance ID

Instance state

Instance type

Status check

Availability Zone

Public IPv4 DNS

Public IPv4

Elastic IP

IPv6 IPs

i-0b9c186632946d478

Running

t3.micro

You are not auth

us-east-2c

ec2-18-218-24-75.us-e...

18.218.24.75

-

-

project-web...

Running

t3.micro

You are not auth

us-east-2c

ec2-3-139-59-19.us-eas...

3.139.59.19

-

-

i-0b9c186632946d478 (root-only-server)

Details

Status and alarms

Monitoring

Security

Networking

Storage

Tags

Instance summary

CloudShell

Agents Toolkit for AWS

Feedback

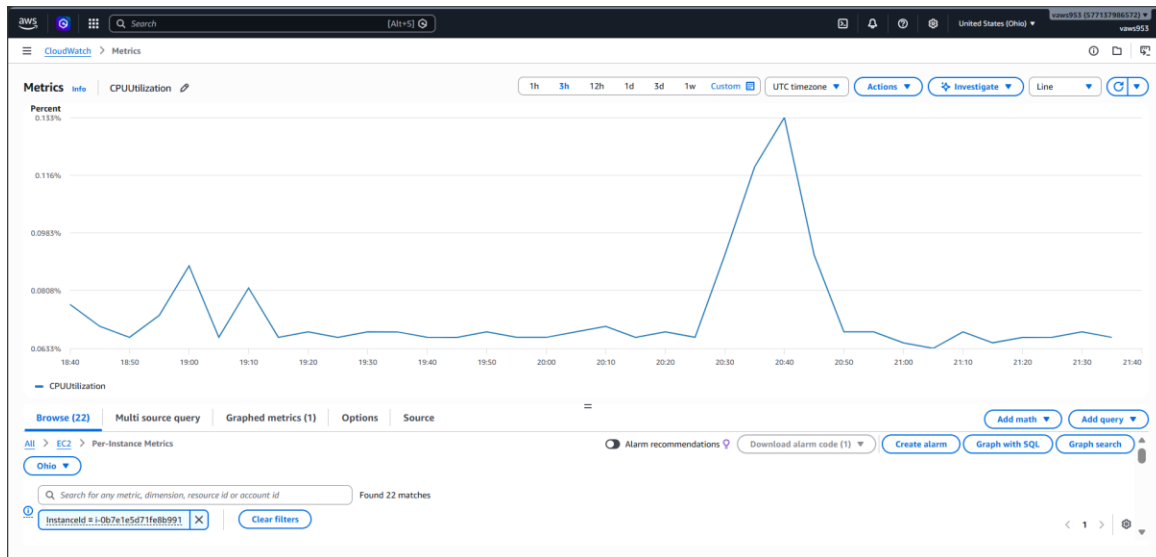
Create Mobile App

© 2026, Amazon Web Services, Inc. or its affiliates. Privacy Terms Cookie preferences

This is a clean, direct Access Denied on the specific StopInstances action against the specific isolated server - proof the least-privilege policy scope actually holds.

Task 3: Logging & Monitoring

CloudWatch



CloudTrail - Console Login

- Event: ConsoleLogin
- User: webserver-user
- Time: July 23, 2026, 17:28:08
- Source IP: 174.93.72.176 (actual IP)
- Result: "ConsoleLogin": "Success"
- MFA Used: "No" - a useful callout: enabling MFA even for IAM users (not just root) is good practice

This proves CloudTrail is automatically logging every single login and action in the account, including exactly when webserver-user signed in, from where, and whether it succeeded.

The screenshot shows the AWS CloudTrail console interface. The top navigation bar includes the AWS logo, a search bar, and the user's account information (vaws953). The breadcrumb trail indicates the current location: CloudTrail > Event history > ConsoleLogin. The left-hand navigation menu lists various options: Dashboard, Data event coverage (marked as 'New'), Event history (selected), Insights, Trails, Lake (with sub-items: Dashboards, Query, Event data stores, Integrations), Settings, Pricing, Documentation, Forums, and FAQs. The main content area displays the details for a 'ConsoleLogin' event. The 'Details' section includes fields for Event time (July 23, 2026, 17:28:08 UTC-04:00), User name (webserver-user), Event name (ConsoleLogin), Event source (signin.amazonaws.com), AWS region (us-east-2), Error code (-), and Read-only status (false). It also lists AWS access key (-), Source IP address (174.93.72.176), Event ID (f323f5b3-7d59-4cd1-ac85-ef02ad33fc70), and Request ID (-). Below the details, the 'Resources referenced' section shows that no resources were referenced. At the bottom, there is an 'Event record' section with a 'Copy' button.

CloudTrail <

Dashboard
Data event coverage **New**
Event history
Insights
Trails

▼ Lake
Dashboards
Query
Event data stores
Integrations

Settings

Pricing [↗](#)
Documentation [↗](#)
Forums [↗](#)
FAQs [↗](#)

ConsoleLogin [Info](#)

Details [Info](#)

Event time
July 23, 2026, 17:28:08 (UTC-04:00)

User name
webserver-user

Event name
ConsoleLogin

Event source
signin.amazonaws.com

AWS region
us-east-2

Error code
-

Read-only
false

AWS access key
-

Source IP address
174.93.72.176

Event ID
f323f5b3-7d59-4cd1-ac85-ef02ad33fc70

Request ID
-

Resources referenced (0) [Info](#)
Resources referenced describes the name or ID of resources that were read or changed by an event

Resource type	Resource name	AWS Config resource timeline
No resources referenced		

Event record [Info](#) [Copy](#)

CloudTrail - StopInstances Denial

CloudTrail's permanent audit record of the exact isolation test:

- Event: StopInstances
- User: webserver-user
- Target: i-0b9c186632946d478 (root-only-server)
- Error code: Client.UnauthorizedOperation
- Error message: explicitly states the user was denied because "no identity-based policy allows the ec2:StopInstances action" on that resource

CloudTrail

>

Event history

>

StopInstances

CloudTrail

<

Dashboard

Data event coverage New

Event history

Insights

Trails

▼ Lake

Dashboards

Query

Event data stores

Integrations

Settings

Pricing ↗

Documentation ↗

Forums ↗

FAQs ↗

StopInstances

Info

Details

Info

Event time

July 23, 2026, 17:32:07 (UTC-04:00)

User name

webserver-user

Event name

StopInstances

Event source

ec2.amazonaws.com

AWS region

us-east-2

Error code

Client.UnauthorizedOperation

Read-only

false

AWS access key

ASIAYMYA2ZQGP7UZNUTO

Source IP address

174.93.72.176

Event ID

bd1f9bdf-c4df-45cc-8b22-50bc4716cb7f

Request ID

69a699ba-c9e8-4ae2-8343-cfb097e0f6d4

Resources referenced (1)

Info

Resources referenced describes the name or ID of resources that were read or changed by an event

Resource type	Resource name	AWS Config resource timeline
AWS::EC2::Instance	i-0b9c186632946d478 ↗	Enable AWS Config resource recording ↗

Event record

Info

Copy

Task 4: CIS Benchmark Hardening

Project Step	CIS Debian Controls
SSH Hardening	5.1.8, 5.1.17, 5.1.18, 5.1.20, 5.1.21(2)
Automatic Updates	7.1.1
UFW Installation	4.1.1
Firewall Rules	4.1.2
AIDE Installation	6.1.1
AIDE Baseline	6.1.2
/etc/passwd Permissions	6.1.4
/etc/shadow Permissions	6.1.8
sudo use <code>pty</code>	5.3.2
Lock Unused Interactive Accounts	7.2.9

Controls 1–7 - SSH Hardening (/etc/ssh/sshd_config)

The following seven controls were applied together by editing /etc/ssh/sshd_config, then restarting sshd:

- Control 1 - PermitRootLogin no - blocks direct SSH login as root.
- Control 2 - PasswordAuthentication no - forces key-only login, no passwords accepted.
- Control 3 - Protocol 2 - enforces the modern, secure SSH protocol version.
- Control 4 - MaxAuthTries 3 - limits login attempts per connection, slowing brute-force attacks.
- Control 5 - ClientAliveInterval 300 - pings idle sessions every 5 minutes.
- Control 6 - ClientAliveCountMax 0 - disconnects immediately if a ping goes unanswered.
- Control 7 - PermitEmptyPasswords no - blocks any account with a blank password from logging in.

Edited sshd_config, then restarted sshd and verified a brand-new SSH connection still succeeded - with no password prompt at all, confirming key-only login was enforced:

```
admin@ip-172-31-43-218: ~
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\System32>cd %USERPROFILE%\Downloads

C:\Users\vigne\Downloads>ssh -i "mykey.pem" admin@3.139.59.19
Linux ip-172-31-43-218 6.12.74+deb13+1-cloud-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1
2.74-2 (2026-03-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Jul 23 20:46:00 2026 from 174.93.72.176
admin@ip-172-31-43-218:~$
```

```
admin@ip-172-31-43-218: ~
GNU nano 8.4 /etc/ssh/sshd_config

# This is the sshd server system-wide configuration file. See
# sshd_config(5) for more information.

# This sshd was compiled with PATH=/usr/local/bin:/usr/bin:/bin:/usr/games

# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented. Uncommented options override the
# default value.

Include /etc/ssh/sshd_config.d/*.conf

#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
MaxAuthTries 3
PasswordAuthentication no
Protocol 2
ClientAliveInterval 300
ClientAliveCountMax 0
PermitEmptyPasswords no
#MaxSessions 10
```

Control 8 - Automatic Security Updates

```
admin@ip-172-31-43-218:~$ sudo apt install unattended-upgrades -y
unattended-upgrades is already the newest version (2.12).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0
```

Control 9 & 10 - Install/Enable UFW Firewall & Verify Status

```

admin@ip-172-31-43-218: ~
admin@ip-172-31-43-218:~$ sudo apt install ufw -y
Installing:
  ufw

Suggested packages:
  rsyslog

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 0
  Download size: 169 kB
  Space needed: 880 kB / 6569 MB available

Get:1 file:/etc/apt/mirrors/debian.list Mirrorlist [38 B]
Get:2 https://cdn-aws.deb.debian.org/debian trixie/main amd64 ufw all 0.36.2-9 [169
kB]
Fetched 169 kB in 0s (2412 kB/s)
Preconfiguring packages ...
Selecting previously unselected package ufw.
(Reading database ... 34509 files and directories currently installed.)
Preparing to unpack .../archives/ufw_0.36.2-9_all.deb ...
Unpacking ufw (0.36.2-9) ...
Setting up ufw (0.36.2-9) ...
Creating config file /etc/ufw/before.rules with new version
Creating config file /etc/ufw/before6.rules with new version
Creating config file /etc/ufw/after.rules with new version
Creating config file /etc/ufw/after6.rules with new version
Created symlink '/etc/systemd/system/multi-user.target.wants/ufw.service' -> '/usr/li
b/systemd/system/ufw.service'.
Processing triggers for man-db (2.13.1-1) ...
admin@ip-172-31-43-218:~$ sudo ufw allow 22/tcp
Rules updated
Rules updated (v6)
admin@ip-172-31-43-218:~$ sudo ufw allow 80/tcp
Rules updated
Rules updated (v6)
admin@ip-172-31-43-218:~$ sudo ufw enable
Firewall is active and enabled on system startup
admin@ip-172-31-43-218:~$ sudo ufw status
Status: active

To                                Action      From
--                                -
22/tcp                            ALLOW       Anywhere
80/tcp                            ALLOW       Anywhere
22/tcp (v6)                       ALLOW       Anywhere (v6)

```

Control 11 - File Integrity Monitoring (AIDE)

```

admin@ip-172-31-43-218:~$ sudo aideinit
Running aide --init...

```

Control 12 - Correct Permissions on /etc/passwd

```

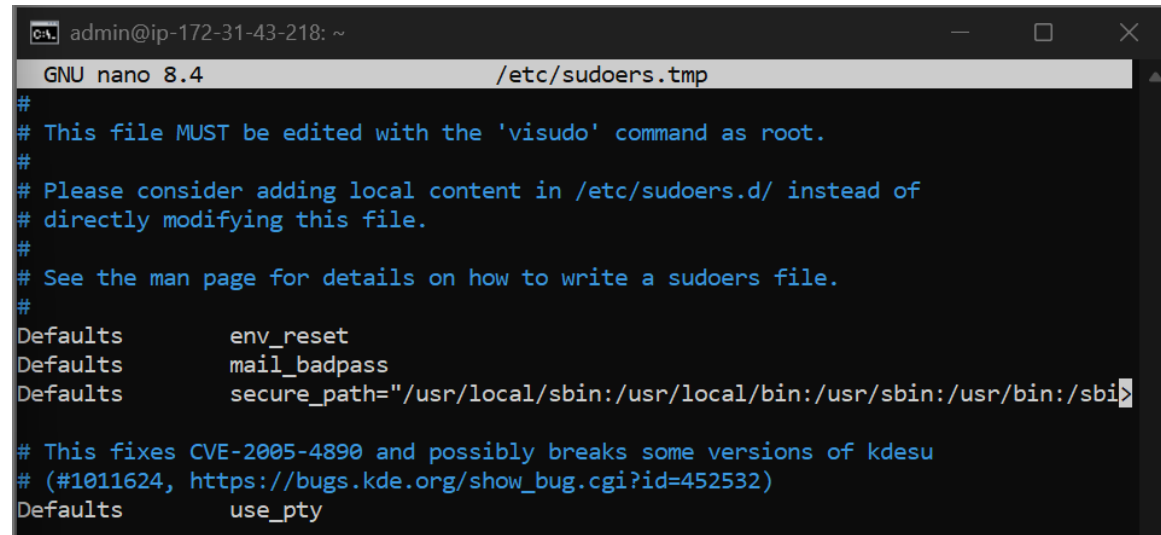
admin@ip-172-31-43-218:~$ sudo chmod 644 /etc/passwd
admin@ip-172-31-43-218:~$ ls -l /etc/passwd
-rw-r--r-- 1 root root 1587 Jul 23 22:39 /etc/passwd

```

Control 13 - Correct Permissions on /etc/shadow

```
admin@ip-172-31-43-218:~$ sudo chmod 640 /etc/shadow
admin@ip-172-31-43-218:~$ ls -l /etc/shadow
-rw-r----- 1 root shadow 777 Jul 23 22:39 /etc/shadow
```

Control 14 - Ensure sudo Commands Use a Pseudo-Terminal (pty)



```
admin@ip-172-31-43-218: ~
GNU nano 8.4 /etc/sudoers.tmp
#
# This file MUST be edited with the 'visudo' command as root.
#
# Please consider adding local content in /etc/sudoers.d/ instead of
# directly modifying this file.
#
# See the man page for details on how to write a sudoers file.
#
Defaults        env_reset
Defaults        mail_badpass
Defaults        secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin"
# This fixes CVE-2005-4890 and possibly breaks some versions of kdesu
# (#1011624, https://bugs.kde.org/show_bug.cgi?id=452532)
Defaults        use_pty

admin@ip-172-31-43-218:~$ sudo cat /etc/sudoers | grep use-pty
```

Control 15 - Disable Login Shell for Unused System Accounts

```
admin@ip-172-31-43-218: ~  
admin@ip-172-31-43-218:~$ cat /etc/passwd  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin  
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin  
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin  
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin  
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin  
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin  
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin  
_apt:x:42:65534:./nonexistent:/usr/sbin/nologin  
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin  
systemd-network:x:998:998:systemd Network Management:./usr/sbin/nologin  
systemd-timesync:x:997:997:systemd Time Synchronization:./usr/sbin/nologin  
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false  
uidd:x:101:101:./run/uidd:/usr/sbin/nologin  
messagebus:x:996:996:System Message Bus:/nonexistent:/usr/sbin/nologin  
tcpdump:x:102:102:./nonexistent:/usr/sbin/nologin  
systemd-resolve:x:990:990:systemd Resolver:./usr/sbin/nologin  
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin  
polkitd:x:988:988>User for polkitd:./usr/sbin/nologin  
admin:x:1000:1000:Debian:/home/admin:/bin/bash  
Debian-exim:x:103:105:./var/spool/exim4:/usr/sbin/nologin  
_aide:x:986:986:Advanced Intrusion Detection Environment:/var/lib/aide:/usr/sbin/nologin
```

Task 5 - CIS Benchmark Controls Checklist

All 15 controls below were applied and verified directly on the project2-web-server instance (Debian 13) via SSH.

#	Control	Command(s) Used	Status
1	Disable root SSH login	PermitRootLogin no	Applied
2	Disable password authentication	PasswordAuthentication no	Applied
3	Enforce SSH Protocol 2	Protocol 2	Applied
4	Limit authentication attempts	MaxAuthTries 3	Applied
5	Auto-disconnect idle sessions (interval)	ClientAliveInterval 300	Applied
6	Auto-disconnect idle sessions (count)	ClientAliveCountMax 0	Applied
7	Disable empty passwords	PermitEmptyPasswords no	Applied
8	Automatic security updates	apt install unattended-upgrades -y	Already present
9	Install & enable firewall (UFW)	apt install ufw; ufw allow 22/tcp; ufw allow 80/tcp; ufw enable	Applied
10	Verify firewall rules	ufw status	Verified
11	File integrity monitoring (AIDE)	apt install aide -y; aideinit	Applied
12	Permissions on /etc/passwd	chmod 644 /etc/passwd	Applied
13	Permissions on /etc/shadow	chmod 640 /etc/shadow	Applied
14	sudo commands use pty	Defaults use pty (via visudo)	Already present
15	Disable unused login shells	Reviewed /etc/passwd for all accounts	Already compliant

Day 3 - Vulnerability Scanning, Application Fixes & Automation

Task 1: Lynis

1. Install Lynis

```
admin@ip-172-31-43-218:~$ sudo apt install lynis -y
Installing:
  lynis

Installing dependencies:
  menu

Suggested packages:
  bind9-dnsutils  debsecan  tripwire  fail2ban
  apt-listbugs    debsums  samhain   menu-l10n

Summary:
  Upgrading: 0, Installing: 2, Removing: 0, Not Upgrading: 3
  Download size: 629 kB
  Space needed: 3282 kB / 6555 MB available

Get:1 file:/etc/apt/mirrors/debian.list Mirrorlist [38 B]
Get:2 https://cdn-aws.deb.debian.org/debian trixie/main amd64 lynis all 3.1.4-1 [273 kB]
Get:3 https://cdn-aws.deb.debian.org/debian trixie/main amd64 menu amd64 2.1.51 [355 kB]
Fetched 629 kB in 0s (8474 kB/s)
Selecting previously unselected package lynis.
(Reading database ... 35243 files and directories currently installed.)
Preparing to unpack .../archives/lynis_3.1.4-1_all.deb ...
Unpacking lynis (3.1.4-1) ...
Selecting previously unselected package menu.
Preparing to unpack .../archives/menu_2.1.51_amd64.deb ...
Unpacking menu (2.1.51) ...
Setting up lynis (3.1.4-1) ...
Created symlink '/etc/systemd/system/timers.target.wants/lynis.timer' → '/usr/lib/systemd/system/lynis.timer'.
lynis.service is a disabled or a static unit, not starting it.
```

2. Check the Version

```
admin@ip-172-31-43-218:~$ lynis show version
-bash: lynis: command not found
```

```
admin@ip-172-31-43-218:~$ which lynis
admin@ip-172-31-43-218:~$ dpkg -L lynis | grep bin
/usr/sbin
/usr/sbin/lynis
/usr/share/lynis/include/binaries
admin@ip-172-31-43-218:~$ sudo /usr/sbin/lynis show version
3.1.4
admin@ip-172-31-43-218:~$
```

Issue Observed: Running `lynis show version` returned `"bash: lynis: command not found"`, despite `apt install lynis -y` reporting the package was already installed.

Diagnostic Steps Taken

- `which lynis` - checked whether the shell's PATH includes the directory containing the Lynis executable. No output confirms a PATH visibility issue rather than a missing installation.
- `dpkg -L lynis | grep bin` - queried Debian's package database for the executable's actual file path (e.g., `/usr/sbin/lynis`).
- `sudo /usr/sbin/lynis show version` - ran Lynis via its full, absolute path, bypassing PATH lookup entirely, to confirm the tool itself works once located.

Root Cause (expected): Lynis is installed under `/usr/sbin/`, a directory typically included in root's PATH but often excluded from a regular (non-root) user's PATH by default on Debian - hence the shell couldn't resolve the bare `lynis` command.

Resolution: Running Lynis with `sudo` (which normally includes `/usr/sbin` in its resolved PATH) or referencing the full path directly resolves the issue going forward.

3. Help

```
admin@ip-172-31-43-218:~$ sudo lynis show help
Lynis 3.1.4 - Help
=====

Commands:
audit
configure
generate
show
update
upload-only

Use 'lynis show help <command>' to see details

Options:
--auditor
--cronjob (--cron)
--debug
--developer
--devops
--forensics
--help (-h)
--log-file
--manpage (--man)
--no-colors
--no-log
--no-plugins
--pentest
--profile
--plugin-dir
--quick (-Q)
--quiet (-q)
--report-file
--reverse-colors
--tests
```

Displays all the available commands and options Lynis supports (audit system, audit dockerfile, --pentest, etc.) - useful as proof of exploring the tool's options.

4. Basic System Audit

```
admin@ip-172-31-43-218:~$ sudo lynis audit system
```

```
[ Lynis 3.1.4 ]
```

```
#####  
#####
```

```
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software  
, and you are  
welcome to redistribute it under the terms of the GNU General  
Public License.
```

```
See the LICENSE file for details about using this software.
```

```
2007-2024, CISOfy - https://cisofy.com/lynis/
```

```
Enterprise support available (compliance, plugins, interface a  
nd tools)
```

```
#####  
#####
```

```
[+] Initializing program
```

```
-----  
- Detecting OS... [ ]  
DONE ]
```

```
- Checking profiles... [ ]  
DONE ]
```

```
-----  
Program version:      3.1.4  
Operating system:     Linux  
Operating system name: Debian  
Operating system version: 13  
Kernel version:       6.12.96+deb13  
Hardware platform:    x86_64  
Hostname:             ip-172-31-43-218  
-----
```

Lynis security scan details:

Hardening index : 69 [#####]
Tests performed : 259
Plugins enabled : 1

Components:

- Firewall [V]
- Malware scanner [X]

Scan mode:

Normal [V] Forensics [] Integration [] Pentest []

Lynis modules:

- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:

- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

=====

Lynis 3.1.4

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2024, CISOfy - <https://cisofy.com/lynis/>

Enterprise support available (compliance, plugins, interface a

5. Review Logs

```
admin@ip-172-31-43-218:~$ sudo grep "Warning" /var/log/lynis.log
2026-07-25 02:16:02 Warning: Can't find any security repository
in /etc/apt/sources.list or sources.list.d directory [test:PKGS-
7388] [details:-] [solution:-]
2026-07-25 02:16:05 Warning: Found one or more vulnerable packag
es. [test:PKGS-7392] [details:-] [solution:-]
```

From this scan, two warnings were surfaced:

Warning 1: No security repository configured

"Can't find any security repository in /etc/apt/sources.list [test:PKGS-7388]"

Debian ships security patches through a special repository, separate from the regular software repository. If this isn't configured, the system won't automatically receive critical security updates - even apt upgrade won't see them.

Warning 2: Vulnerable packages found

"Found one or more vulnerable packages. [test:PKGS-7392]"

At least one installed package has a known, published vulnerability (CVE) that hasn't been patched yet.

6. Fix at Least Two Recommendations

Warning 1: No security repository configured

```
admin@ip-172-31-43-218:~$ cat /etc/apt/sources.list
# See /etc/apt/sources.list.d/debian.sources
admin@ip-172-31-43-218:~$ cat /etc/apt/sources.list.d/debian.sources
Types: deb deb-src
URIs: mirror+file:///etc/apt/mirrors/debian.list
Suites: trixie trixie-updates trixie-backports
Components: main
Signed-By: /usr/share/keyrings/debian-archive-keyring.gpg

Types: deb deb-src
URIs: mirror+file:///etc/apt/mirrors/debian-security.list
Suites: trixie-security
Components: main
Signed-By: /usr/share/keyrings/debian-archive-keyring.gpg
```

Lynis warning PKGS-7388 flagged a missing security repository. Manual verification of /etc/apt/sources.list.d/debian.sources confirmed the trixie-security repository is correctly configured using Debian's newer DEB822 source format, which this Lynis check does not yet recognize. Determined to be a false positive; no action needed.

Warning 2: Vulnerable packages found

```

admin@ip-172-31-43-218:~$ sudo grep -A 5 "PKGS-7392" /var/log/lynis.log
2026-07-25 02:16:03 Performing test ID PKGS-7392 (Check for Debian/Ubuntu security updates)
2026-07-25 02:16:03 Action: updating package repository with apt-get
2026-07-25 02:16:04 Result: apt-get finished
2026-07-25 02:16:04 Test: Checking if /usr/lib/update-notifier/apt-check exists
2026-07-25 02:16:04 Result: apt-check (update-notifier-common) not found
2026-07-25 02:16:05 Result: found vulnerable package(s) via apt-get (-security channel)
--
2026-07-25 02:16:05 Warning: Found one or more vulnerable packages. [test:PKGS-7392] [details:-] [solution:-]
2026-07-25 02:16:05 Suggestion: Update your system with apt-get update, apt-get upgrade, apt-get dist-upgrade and/or unattended-upgrades [test:PKGS-7392] [details:-] [solution:-]
2026-07-25 02:16:05 ====
2026-07-25 02:16:05 Skipped test PKGS-7393 (Check for Gentoo vulnerable packages)
2026-07-25 02:16:05 Reason to skip: Prerequisites not met (ie missing tool, other type of Linux distribution)
2026-07-25 02:16:05 ====
2026-07-25 02:16:05 Performing test ID PKGS-7394 (Check for Ubuntu updates)

```

Checking for updates:

- sudo apt update
- sudo apt upgrade -y
- sudo apt dist-upgrade -y

```

admin@ip-172-31-43-218:~$ sudo apt upgrade -y
Upgrading:
exim4-base exim4-config exim4-daemon-light

```

Suggestion 1: Missing Malware Scanner

Test ID: HRDN-7230 | Severity: Suggestion

Description: Lynis identified no malware scanning tool installed on the system, leaving the "Malware scanner" component unchecked.

Resolution: rkhunter installed and baseline file property database initialized, enabling periodic rootkit/malware detection scans.

- sudo apt install rkhunter -y
- sudo rkhunter --update
- sudo rkhunter --propupd

```

admin@ip-172-31-43-218:~$ sudo apt install rkhunter -y
Installing:
  rkhunter

Installing dependencies:
  binutils          rake
  binutils-common   ruby
  binutils-x86-64-linux-gnu  ruby-csv
  fonts-lato         ruby-did-you-mean
  javascript-common  ruby-net-telnet
  libbinutils        ruby-ruby2-keywords
  libctf-nobfd0      ruby-rubygems
  libctf0            ruby-sdbm
  libgprofng0        ruby-webrick
  libjs-jquery       ruby-xmlrpc
  liblsof0           ruby3.3
  libruby            rubygems-integration
  libruby3.3         unhide
  libsframe1         unhide.rb
  lsof               unzip
  net-tools          zip

```

Suggestion 2: Missing Brute-Force Protection

Test ID: DEB-0880 | Severity: Suggestion

Description: Lynis recommended installing fail2ban to automatically block hosts after repeated failed authentication attempts.

- `sudo apt install fail2ban -y`
- `sudo systemctl enable fail2ban`
- `sudo systemctl start fail2ban`

```

admin@ip-172-31-43-218:~$ sudo apt install fail2ban -y
Installing:
  fail2ban

Installing dependencies:
  python3-autocommand  python3-pyasyncore
  python3-inflate      python3-pyinotify
  python3-jaraco.context  python3-setuptools
  python3-jaraco.functools  python3-systemd
  python3-jaraco.text     python3-typeguard
  python3-more-itertools  python3-typing-extensions
  python3-pkg-resources   whois

Suggested packages:
  system-log-daemon  python-pyinotify-doc
  monit              python-setuptools-doc
  sqlite3

```

```
admin@ip-172-31-43-218:~$ sudo systemctl enable fail2ban
Synchronizing state of fail2ban.service with SysV service script
with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable fail2ban
admin@ip-172-31-43-218:~$ sudo systemctl start fail2ban
```

7. Check Security Score

Before fixing the warnings: hardening_index = 69

Lynis security scan details:

```
Hardening index : 69 [#####          ]
Tests performed : 259
Plugins enabled : 1
```

After fixing the two warnings: hardening_index = 70

Lynis security scan details:

```
Hardening index : 70 [#####          ]
Tests performed : 264
Plugins enabled : 1
```

8. Check Running Services and Status

```
admin@ip-172-31-43-218:~$ sudo systemctl list-units --type=service --state=running
```

```
17 loaded units listed.
lines 1-24/24 (END)
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
apache2.service                    loaded active running The Apache HTTP Server
cron.service                        loaded active running Regular background program processing daemon
dbus.service                       loaded active running D-Bus System Message Bus
exim4.service                      loaded active running exim Mail Transport Agent
fail2ban.service                   loaded active running Fail2Ban Service
getty@tty1.service                 loaded active running Getty on tty1
polkit.service                     loaded active running Authorization Manager
serial-getty@ttyS0.service          loaded active running Serial Getty on ttyS0
ssh.service                         loaded active running OpenBSD Secure Shell server
systemd-journald.service            loaded active running Journal Service
systemd-logind.service              loaded active running User Login Management
systemd-networkd.service            loaded active running Network Configuration
systemd-resolved.service            loaded active running Network Name Resolution
systemd-timesyncd.service           loaded active running Network Time Synchronization
systemd-udevd.service               loaded active running Rule-based Manager for Device Events and Files
unattended-upgrades.service         loaded active running Unattended Upgrades Shutdown
user@1000.service                  loaded active running User Manager for UID 1000
```

Example - fail2ban status:

```
admin@ip-172-31-43-218:~$ sudo systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; e
nabled; preset: enabled)
   Active: active (running) since Sat 2026-07-25 02:43:15 UTC;
19min ago
  Invocation: 06066b7dbe864326991a4ea27cedb14d
     Docs: man:fail2ban(1)
    Main PID: 184543 (fail2ban-server)
       Tasks: 5 (limit: 1097)
      Memory: 12.8M (peak: 14.9M)
         CPU: 894ms
        CGroup: /system.slice/fail2ban.service
                └─184543 /usr/bin/python3 /usr/bin/fail2ban-server

-xf start

Jul 25 02:43:15 ip-172-31-43-218 systemd[1]: Started fail2ban.se
rvice - Fail2Ban Service.
Jul 25 02:43:15 ip-172-31-43-218 fail2ban-server[184543]: Server
ready
```

Task 2: AWS Inspector

Planned steps (outlined for future completion):

- 1. Enable it
- 2. First scan
- 3. Review vulnerability findings
- 4. Identify high severity issues
- 5. Apply patch
- 6. Perform scan again
- 7. Scan the container images (optional) - ECR

Task 3: Apache Directory Browsing Fix

1. Locate the relevant configuration block

```
sudo grep -n "Directory /var/www" /etc/apache2/apache2.conf
```

2. View the block to confirm its content

```
sudo sed -n '169,173p' /etc/apache2/apache2.conf
```

```
<Directory />
    Options FollowSymLinks
    AllowOverride None
    Require all denied
</Directory>

<Directory /usr/share>
    AllowOverride None
    Require all granted
</Directory>

<Directory /var/www/>
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>
```

```
admin@ip-172-31-43-218:~$ sudo cat /etc/apache2/apache2.conf | g
rep -A 4 "/var/www/"
<Directory /var/www/>
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>
```

3. Apply the fix directly with sed (reliable, no editor needed)

```
sudo sed -i 's/Options Indexes FollowSymLinks/Options FollowSymLinks/'  
/etc/apache2/apache2.conf
```

4. Verify the change actually saved

```
sudo grep -A 4 "Directory /var/www" /etc/apache2/apache2.conf
```

```
admin@ip-172-31-43-218:~$ sudo grep -A 4 "Directory /var/www" /e  
tc/apache2/apache2.conf  
<Directory /var/www/>  
    Options FollowSymLinks  
    AllowOverride None  
    Require all granted  
</Directory>
```

5. Restart Apache to apply the change

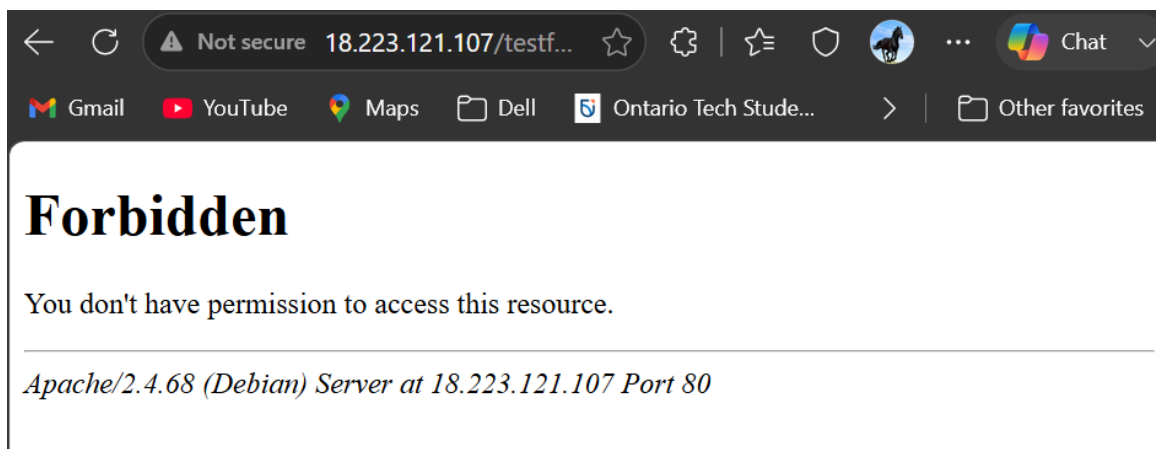
```
sudo systemctl restart apache2
```

6. Create a test folder (to prove the fix works)

```
sudo touch /var/www/html/testfolder/somefile.txt
```

7. Test in your browser

```
http://<your-current-EC2-public-IP>/testfolder/
```



Automation: [cis_harden.sh](#)

Create the script:

```
nano cis_harden.sh
```

```

GNU nano 8.4                                cis_harden.sh *
#!/bin/bash
# CIS Benchmark Automation Script - 10 Controls (Debian 13)
# Run with: sudo bash cis_harden.sh

echo "Applying CIS Control 1: Disable root SSH login..."
sed -i 's/^#*PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config

echo "Applying CIS Control 2: Disable password authentication..."
sed -i 's/^#*PasswordAuthentication.*/PasswordAuthentication no/' /etc/ssh/sshd_config

echo "Applying CIS Control 3: Enforce SSH Protocol 2..."
sed -i 's/^#*Protocol.*/Protocol 2/' /etc/ssh/sshd_config

echo "Applying CIS Control 4: Limit authentication attempts..."
sed -i 's/^#*MaxAuthTries.*/MaxAuthTries 3/' /etc/ssh/sshd_config

echo "Applying CIS Control 5: Disable empty passwords..."
sed -i 's/^#*PermitEmptyPasswords.*/PermitEmptyPasswords no/' /etc/ssh/sshd_config

echo "Restarting SSH to apply changes 1-5..."
systemctl restart sshd

echo "Applying CIS Control 6: Install and enable UFW firewall..."

apt install ufw -y
ufw allow 22/tcp
ufw allow 80/tcp
ufw --force enable

echo "Applying CIS Control 7: Correct /etc/passwd permissions..."
chmod 644 /etc/passwd

echo "Applying CIS Control 8: Correct /etc/shadow permissions..."
chmod 640 /etc/shadow

echo "Applying CIS Control 9: Ensure sudo commands use pty..."
if ! grep -q "^Defaults.*use_pty" /etc/sudoers; then
    echo "Defaults use_pty" >> /etc/sudoers
fi

echo "Applying CIS Control 10: Disable Apache directory browsing..."
sed -i 's/Options Indexes FollowSymLinks/Options FollowSymLinks/' /etc/apache2/apache2.conf
systemctl restart apache2

echo ""
echo "All 10 CIS controls applied successfully."
echo "Verifying firewall status:"
ufw status
echo ""
echo "Verifying SSH settings:"
sshd -T | grep -E "permitrootlogin|passwordauthentication|maxauthtries|permitemptypasswords"

```

Make the file executable:

```
chmod +x cis_harden.sh
```

Run the file:

```
sudo bash cis_harden.sh
```

```
admin@ip-172-31-43-218:~$ sudo bash cis_harden.sh
Applying CIS Control 1: Disable root SSH login...
Applying CIS Control 2: Disable password authentication...
Applying CIS Control 3: Enforce SSH Protocol 2...
Applying CIS Control 4: Limit authentication attempts...
Applying CIS Control 5: Disable empty passwords...
Restarting SSH to apply changes 1-5...
Applying CIS Control 6: Install and enable UFW firewall...
ufw is already the newest version (0.36.2-9).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0
Skipping adding existing rule
Skipping adding existing rule (v6)
Skipping adding existing rule
Skipping adding existing rule (v6)
Firewall is active and enabled on system startup
Applying CIS Control 7: Correct /etc/passwd permissions...
Applying CIS Control 8: Correct /etc/shadow permissions...
Applying CIS Control 9: Ensure sudo commands use pty...
Applying CIS Control 10: Disable Apache directory browsing...

All 10 CIS controls applied successfully.
Verifying firewall status:
Status: active
```

To	Action	From
--	-----	----
22/tcp	ALLOW	Anywhere
80/tcp	ALLOW	Anywhere
22/tcp (v6)	ALLOW	Anywhere (v6)
80/tcp (v6)	ALLOW	Anywhere (v6)

Task 4: OWASP Top 10 for Cloud Security

#	OWASP Cloud Risk	Related CWE(s)
1	Insecure Identities, Credentials, Secrets, and Access Management	CWE-798, CWE-287, CWE-306, CWE-522, CWE-259, CWE-269
2	Insecure Interfaces and APIs	CWE-20, CWE-79, CWE-89, CWE-352, CWE-918
3	Misconfiguration and Inadequate Change Control	CWE-16, CWE-276, CWE-732, CWE-250
4	Lack of Cloud Security Architecture and Strategy	CWE-657, CWE-668, CWE-284
5	Insecure Software Development	CWE-20, CWE-79, CWE-89, CWE-502, CWE-94
6	Unsecured Third-Party Resources	CWE-829, CWE-1104, CWE-1357
7	System Vulnerabilities	CWE-1104, CWE-119, CWE-787, CWE-416
8	Accidental Cloud Data Disclosure	CWE-200, CWE-201, CWE-359, CWE-312
9	Misconfiguration of Cloud Services	CWE-16, CWE-732, CWE-284, CWE-276
10	Insufficient Cloud Security Monitoring and Incident Response	CWE-778, CWE-223, CWE-117

Key Findings

- A written policy is not proof it works - the IAM least-privilege policy was only confirmed effective by testing it against an out-of-scope resource and capturing the resulting Access Denied via CloudTrail.
- Not every scanner finding is a real issue - Lynis flagged a missing security repository that turned out to be a false positive due to Debian's newer DEB822 source format. Verifying manually before "fixing" it avoided an unnecessary change.
- Account-level blockers are worth documenting honestly - GuardDuty couldn't be enabled due to a pending AWS account verification step, noted as a known limitation rather than skipped silently.
- Manual hardening doesn't scale - packaging the 15 CIS controls into `cis_harden.sh` turns a one-time manual exercise into a reusable, repeatable process..

About

Built as hands-on portfolio work for SOC Analyst, IAM Analyst, and Cloud Security roles.

Connect: [linkedin.com/in/vigneshgk9securityanalyst](https://www.linkedin.com/in/vigneshgk9securityanalyst)